



Relatório de Teste de Intrusão

Ambiente / Escopo

<DATA DO TESTE>

DIT - CIBERSEGURANÇA

SEGURANÇA OFENSIVA



Teste de Intrusão - TDI-2025-XXX

1. Informações	3
2. Uso deste relatório	3
3. Limitações	3
4. Testes Realizados	3
5. Narrativa e Objetivos	5
.01 MITRE ATT&CK	5
MITRE ATT&CK - Táticas	5
MITRE ATT&CK - Técnicas	6
.02 Checklist OWASP - WASTG	7
Checklist OWASP - MASTG	8
6. Histórico	10
.01 Vulnerabilidades	10
.02 Revisão	10
7. Descrição técnica das vulnerabilidades	11
.01 TESTE	11
.02 TESTE	12
8. Matriz Vulnerabilidade	13



1. Informações

Contato Técnico	ericepaulo@hotmail.com		
Data de Início / Fim	05/07/2022 > 07/07/2022		
Tipo de Teste	Pentest Web	Ambiente	Produção
Aplicação/Escopo	Host/Aplicação: teste Escopo: *	Modalidade	GreyBox BlackBox WhiteBox

2. Uso deste relatório

Esse relatório tem a finalidade de informar brechas de segurança encontradas, sem a finalidade de corrigi-las, aplicações testadas e apresentadas pertencem ao CNPJ: 60.746.948/0001-12 | **Banco Bradesco S.A.**

Todos os dados apresentados, credenciais utilizadas e vulnerabilidades apresentadas são reais, portanto são dados sensíveis e confidenciais.

3. Limitações

Resultados apresentados neste relatório refletem apenas o momento em que a aplicação foi analisada, sem garantir que todas as vulnerabilidades existentes na aplicação estejam relatadas neste documento.

O trabalho desenvolvido pelo analista **NÃO** tem como objetivo corrigir as possíveis vulnerabilidades, nem proteger a contratante contra ataques internos e externos, tem apenas o objetivo fazer um levantamento dos riscos e recomendar formas para minimizá-los.

As recomendações sugeridas neste relatório devem ser testadas e validadas pela equipe técnica responsável antes de serem implementadas no ambiente de produção. O analista **NÃO** se responsabiliza por essa implementação e possíveis impactos que possam vir a ocorrer em outras aplicações ou serviços.

4. Testes Realizados

Os testes realizados foram feitos manualmente, com uso de ferramentas de segurança a fim de auxiliar na realização dos mesmos. Principais testes realizados seguem a **OWASP Top 10**, **NIST** e **Top 25 SANS**, dentre outras práticas



Teste de Intrusão - TDI-2025-XXX

recomendadas pelo mercado de segurança da informação. Para mais informações, verificar o tópico 5 do relatório.

Confidencial



5. Narrativa e Objetivos

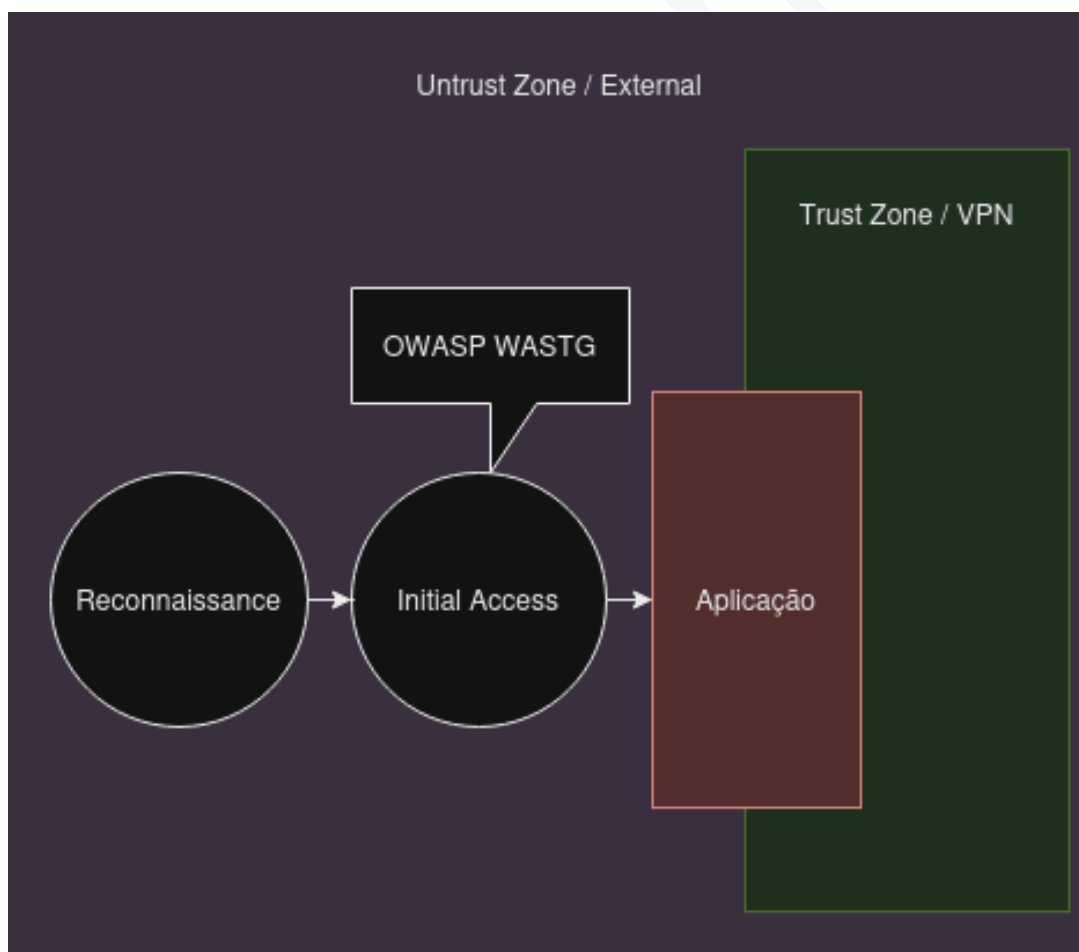
O tem o objetivo de informar em detalhes e a narrativa a qual foi guiado os testes, informando seus objetivos, limitações, motivos, testes realizados e quaisquer demais informações relevantes para registro pelo analista.

Introdução	O teste realizado teve como escopo o produto X,
Objetivo	O objetivo do teste foi avaliar a segurança implementada
Observações	Durante a realização dos testes, foi notado pela parte do analista....

○ MITRE ATT&CK

O teste foi conduzido utilizando a metodologia MITRE ATT&CK, o qual, para o pentest em questão realizado teve as seguintes etapas e TTPs realizados:

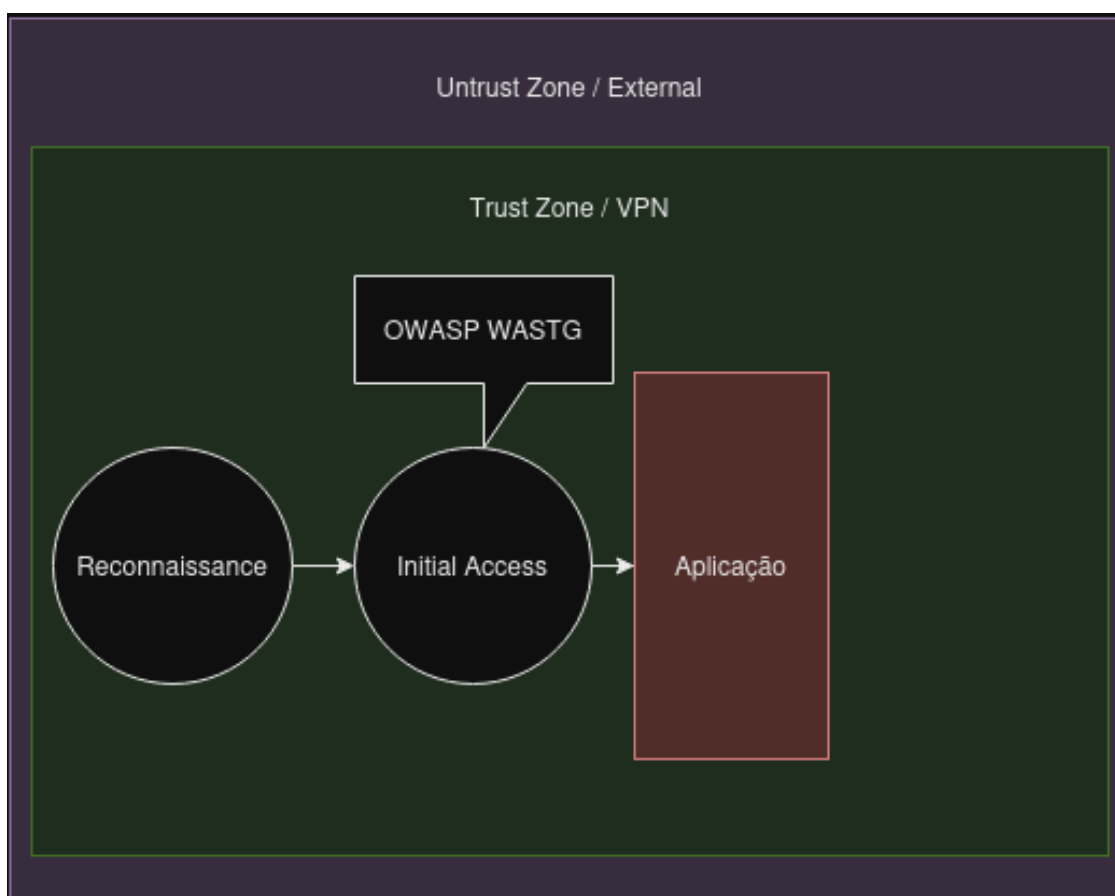
MITRE ATT&CK - Táticas



Origem do teste **externo**, visando atacar uma aplicação **exposta externamente para internet**.



Teste de Intrusão - TDI-2025-XXX



Origem do teste dentro da rede **interna**, visando atacar uma aplicação **exposta apenas internamente**.

MITRE ATT&CK - Técnicas

TTP	Objetivo	Etapa	Check
T1596 - Search Open Technical Databases T1593 - Search Open Website Domains: * T1593.002 - Search Engines (Black Box - Recon Passivo)	Realizar coleta de informações sobre o alvo/host passivamente, como subdomínios, certificado, diretórios utilizando ferramentas públicas.	Recon	Realizado
T1595.003 - Wordlist Scanning (Black Box - Recon)	Realizar coleta de informações sobre o alvo/host ativamente, realizando ataques de brute-force para descobrir subdomínios e diretórios.	Recon	Não realizado



Teste de Intrusão - TDI-2025-XXX

Ativo)			
T1593 - Search Open Website Domains: * T1593.003 - Code Repositories (White Box - Code Review)	Realizar code review da aplicação, a fim de encontrar vulnerabilidades, informações sensíveis.	Recon	
T1190 - Exploit Public-Facing Application (OWASP WASTG)	Procurar vulnerabilidades na aplicação exposta, visando comprometer sua integridade, confidencialidade e disponibilidade.	Initial Access	Não se aplica

○ Checklist OWASP - WASTG

https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/

Tópico checklist tem a função de informar quais testes foram ou não realizados referente a aplicação em questão, tendo 3 possíveis respostas:

- **“Realizado”** o qual informa que foram feitos testes referentes ao tópico.
- **“Não realizado”** o qual informa que não foram feitos testes em relação ao tópico, e o mesmo existe na aplicação, porém por questões externas (como limitação de escopo ou tempo) o mesmo não foi realizado.
- **“Não se aplica”** o qual informa que o teste não foi realizado, pois não faz sentido para a aplicação em questão, por conta de funcionalidades as quais estão atreladas ao teste não existirem na mesma, ou estar fora do escopo solicitado de testes.

Teste realizado	Check
Coleta de Informações	Realizado
Testes de Configuração e Gerenciamento de Implementação	Não realizado
Testes Gerenciamento de Identidade	Não se aplica



Teste de Intrusão - TDI-2025-XXX

Testes de Autenticação	
Testes de Autorização	
Testes Gerenciamento de Sessao	
Testes Validação de Entrada de Dados	
Testes Tratamento de Erros	
Testes para Criptografia Frágil	
Testes de Lógica de Negócios	
Testes a Nível do Cliente	

Checklist OWASP - MASTG

<https://mas.owasp.org/MASTG/tests/>

Teste realizado	Check	Tipo
Security Misconfigurations (ex: debug e backup ativo)	Realizado	Estático
Validar recursos exportados (Activity, Provider, Service, Receiver)	Não realizado	Estático
Permissões solicitadas/excessivas	Não se aplica	Estático
Vazamento de informações sensíveis via logs/logcat		Estático
Vazamento de informações sensíveis hardcoded		Estático



Teste de Intrusão - TDI-2025-XXX

Armazenamento inseguro		Estático
Testes em bibliotecas e recursos de terceiros		Estático
Testes de injeção (ex: SQLi content-providers, XSS Webview)		Dinâmico
Testes de bypass/enumeração de controles (ex: anti-root, anti-tampering)		Interativo
Testes MiM (Web)		Dinâmico



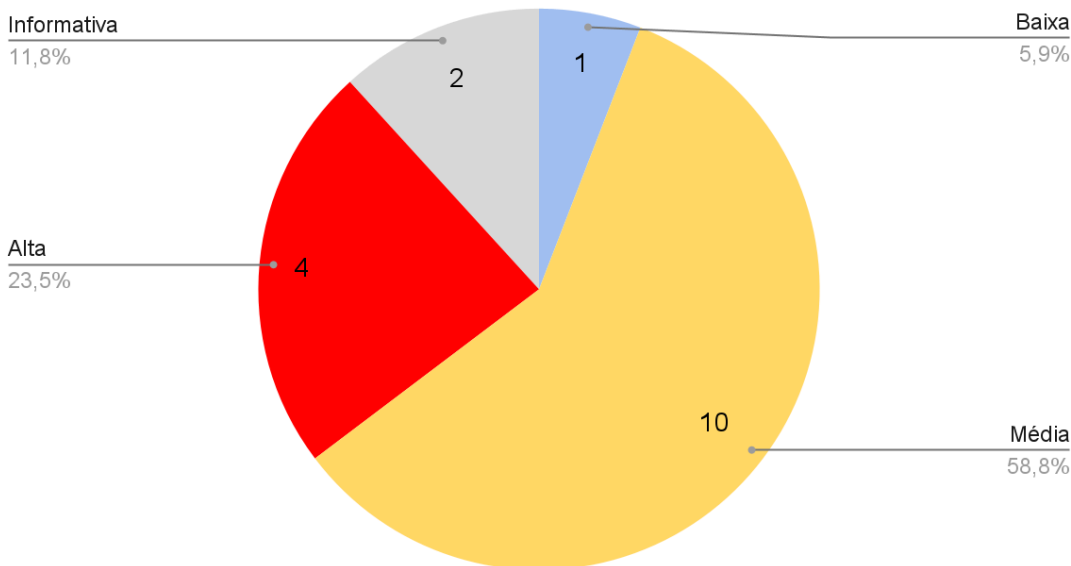
6. Histórico

Vulnerabilidades

A tabela com histórico mostra a evolução da solicitação ao longo da realização de novos testes/retestes, informando quando vulnerabilidades foram abertas/encontradas e fechadas/corrigidas.

ID	Analista	Data	Vulnerabilidade	Criticidade	Status
2023-XXX-01	Eric Evideira Paulo	xx/xx/xx	Aplicação não valida assinatura JWT.	Média	Aberto
2023-XXX-02	Eric Evideira Paulo	xx/xx/xx	Aplicação não valida assinatura JWT.	Média	Fechado

Criticidade das Vulnerabilidades Encontradas





Revisão

A tabela com histórico de revisão visa informar todas modificações realizadas no documento em questão para controle interno.

Versão	Data	Analista	Descrição
1.0	xx/xx/xx	Eric Evideira Paulo	Criação do Documento



7. Descrição técnica das vulnerabilidades

Os parâmetros utilizados para classificação de severidade das vulnerabilidades foram baseados na metodologia aplicada pelo CVSS, disponível em:

<https://www.first.org/cvss/calculator/3.1>

○ TESTE

CVSS Score: Criticidade Crítica
CVSS:3.1/
CWE-:

Aplicação/Rota Afetada	/:*
Explicação da Vulnerabilidade	
Riscos	

Evidências e informações adicionais:

--

Figura x -

Evidências de correção: --

Recomendação de correção	
Referências	



Teste de Intrusão - TDI-2025-XXX

○ TESTE

CVSS Score: Criticidade Crítica
CVSS:3.1/
CWE-:

CVSS Score: Criticidade Alta
CVSS:3.1/
CWE-:

CVSS Score: Criticidade Média
CVSS:3.1/
CWE-7:

CVSS Score: Criticidade Baixa
CVSS:3.1/
CWE-:

CVSS Score: 0.0 Criticidade Informativa
CVSS:3.1/
CWE-347:



8. Matriz Vulnerabilidade

Para o cálculo de criticidade foi utilizado a metodologia utilizada pelo NIST CVSS <https://nvd.nist.gov/vuln-metrics/cvss>. Abaixo segue um informativo para cada criticidade.

Vulnerabilidade Criticidade Crítica CVSS: 9.0 > 10.0	Vulnerabilidades de criticidade “Crítica” são caracterizadas por comprometer completamente a confidencialidade, integridade e avaliabilidade da aplicação, por meio de ataques de baixa complexidade ou da falta de privilégios requeridos para realização do ataque. Exemplo: SQL Injection, RCE (Remote Control Execution).
Vulnerabilidade Criticidade Alta CVSS: 7.0 > 8.9	Vulnerabilidades de criticidade “Alta” são caracterizadas por comprometer quase totalmente a confidencialidade, integridade e avaliabilidade da aplicação. Exemplo: SSRF, Broken Authentication.
Vulnerabilidade Criticidade Média CVSS: 4.0 > 6.9	Vulnerabilidades de criticidade “Média” são caracterizadas por comprometer parcialmente a confidencialidade, integridade e avaliabilidade da aplicação, por meio de ataques de alta complexidade ou do excesso de privilégios requeridos para realização do ataque. Exemplo: Improper Input Validation, CSRF.
Vulnerabilidade Criticidade Baixa CVSS: 0.1 > 3.9	Vulnerabilidades de criticidade “Baixa” são caracterizadas por comprometer parcialmente a confidencialidade, integridade ou avaliabilidade da aplicação, como vazamento de dados sensíveis e falhas de configuração. Exemplo: Uncaught Exception, Clickjacking.
Vulnerabilidade Criticidade Informativa CVSS: 0.0	Vulnerabilidades de criticidade “Informativa” são caracterizadas por não comprometer a confidencialidade, integridade e avaliabilidade da aplicação, são apenas recomendações de segurança.